Auditoria do sistema IdeiaTech

Relatório de prontidão para apresentação do MVP

Avaliação funcional, técnica, estrutural e visual para apoiar a preparação da demonstração prevista para 23 de outubro de 2026 à tarde.

RESULTADO	EVIDÊNCIA	DECISÃO PARA A DEMO
Adequado para demonstração local guiada, com ressalvas.	20 testes automatizados passaram; 25 páginas HTML e recursos locais percorridos via HTTP.	Alinhar a narrativa da IdeiaAI ao comportamento atual e ensaiar com contas/dados preparados.

Conclusão executiva

Não foi encontrada falha crítica reproduzível nesta rodada. Os fluxos de pedidos/estoque e edição de dados empresariais têm testes automatizados úteis. A principal exposição na apresentação é a discrepância entre a promessa de análise por IA e a implementação atual, que devolve conteúdo e valores fixos por categoria. A cobertura automatizada não representa todos os fluxos do produto, e não houve ensaio visual em navegadores/tamanhos variados nem validação de produção.

Legenda de gravidade

Alta: pode comprometer credibilidade ou resultado central da demonstração. Média: risco relevante de falha/regressão ou dependência que requer preparação. Baixa: melhoria de qualidade com impacto limitado no roteiro de amanhã.

1. Escopo e método

- Inspeção das rotas Flask, páginas HTML, scripts JavaScript, estilos CSS, configuração e estrutura SQLite.
- Execução da suíte existente de BackEnd/tests: unittest discover -s BackEnd/tests.
- Smoke test HTTP das 25 páginas; páginas públicas retornaram 200 e páginas protegidas redirecionaram usuários anônimos (302). Recursos locais em Style, Script e Assets retornaram 200.
- Revisão estática de autenticação/sessão, CSRF, recuperação de senha, carrinho/pedidos, orçamento e serviços externos citados no código.
- Leitura da documentação de execução local e requisitos declarados para configuração de produção.

Como interpretar o resultado

O smoke test confirma resposta HTTP e controle básico de acesso anônimo; não equivale à navegação completa de cada formulário. A análise estática identifica comportamento provável pelo código, mas não substitui teste de uso. Os achados abaixo diferenciam evidência observada, inferência de risco e ação recomendada.

2. Fluxos do sistema e cobertura observada

As rotas e páginas encontradas mostram dois percursos principais, cliente e empresa. “Não exercitado de ponta a ponta” significa que o fluxo foi mapeado no código, mas não validado integralmente por automação nesta rodada.

ÁREA / FLUXO	O QUE FOI IDENTIFICADO	COBERTURA NESTA AUDITORIA
Acesso e conta	Cadastro cliente/empresa, login, sessão, logout, recuperação e redefinição de senha.	Páginas públicas no smoke; estrutura/CSRF inspecionados. Sem suíte ampla de cadastro/login/recuperação.
Perfil e endereço	Visualização/edição de perfil, endereço e consulta de frete.	Rotas identificadas e controle de acesso inspecionado; percurso completo não exercitado.
Vitrine e compra	Catálogo, carrinho, consulta/uso de endereço, frete, criação e acompanhamento de pedidos.	Testes cobrem criação, estoque, agrupamento por empresa, status e cancelamento; fluxo de tela completo não exercitado.
Assistência e coleta	Solicitação de atendimento, descrição do problema, modalidade loja/coleta e consulta de CEP.	Rotas/scripts inspecionados; dependência ViaCEP identificada; sem teste ponta a ponta.
Análise e orçamento	Análise preliminar, geração/apresentação de faixa e prazo, envio da solicitação e decisão do cliente.	Endpoint estático examinado; caminho completo cliente-empresa-cliente sem testes automatizados identificados.

ÁREA / FLUXO	O QUE FOI IDENTIFICADO	COBERTURA NESTA AUDITORIA
Acompanhamento técnico	Acompanhamento de ordens, preferências de entrega e mudança de etapas.	Rotas e páginas identificadas; sem suíte automatizada ampla de transições nesta rodada.
Operação empresarial	Painel, dados da empresa, aparelhos, solicitações, orçamentos, produtos, pedidos e ordens de serviço.	Testes específicos de dados empresariais e gestão de pedidos; demais páginas privadas redirecionaram anonimamente.
Interface e responsividade	HTML, CSS, recursos e composição de páginas.	Recursos locais retornaram 200. Não foi feito ensaio visual em viewport/navegadores variados nem auditoria de acessibilidade.

3. Achados e gravidade

Alta | IdeiaAI é apresentada como análise por IA, mas a resposta é fixa

Evidência: POST /api/orcamento/analisar em BackEnd/app.py escolhe mensagens, faixas de preço e prazos a partir de dicionários indexados pela categoria. A rota não consulta BackEnd/ia_prompt.py nem um provedor de modelo. A tela/script descreve o processo como análise IdeiaAI. As faixas são atribuídas genericamente a referências brasileiras de 2026, sem referências verificáveis apresentadas ao usuário.

Risco: um público técnico pode perguntar qual modelo é usado, como se controla a resposta e quais fontes sustentam os valores. O comportamento do produto não sustenta a afirmação de inferência por IA, e a precisão aparente dos valores pode ser interpretada como dado validado.

Ação para amanhã: apresentar como “triagem preliminar” ou “estimativa orientativa por categoria”, explicando que preço e prazo são referências ilustrativas a confirmar pela assistência. Se a narrativa exigir IA real, a integração e validação precisam ocorrer antes de manter essa afirmação.

Média | Cobertura automatizada é estreita para a quantidade de percursos

Evidência: os 20 testes concentram-se em pedidos/estoque e dados empresariais. Não foi localizada cobertura automatizada equivalente para cadastro, login, recuperação, perfil/endereço, frete, atendimento/coleta, orçamento e decisão do cliente, ordens e transições de status, responsividade ou acessibilidade.

Risco: áreas sem testes podem regredir sem que a suíte atual indique problema. Ação: para a demo, percorrer manualmente o roteiro escolhido e conferir as contas; depois, ampliar testes de integração nos fluxos de orçamento, atendimento e autenticação.

Média | Serviços externos podem degradar a experiência da demo

Evidência: a busca de CEP de coleta chama o ViaCEP no navegador e algumas páginas carregam Google Fonts. A inspeção confirmou apenas os recursos locais, não a disponibilidade dessas dependências externas.

Risco e ação: rede instável pode impedir a consulta do CEP ou mudar a tipografia. Ensaiar no local/rede do evento, testar preenchimento manual e deixar dados de demonstração prontos.

Baixa | Validação de e-mail é permissiva em partes do cadastro

Evidência: validações de servidor usam presença de “@” como verificação básica em alguns caminhos. Risco: endereços malformados podem persistir e falhar em recuperação ou comunicação. Melhorar com validação de formato consistente e confirmação por e-mail quando o serviço estiver ativo.

Baixa | Ambiente de produção não comprovado

Evidência: COMO_RODAR.md descreve a execução local como desenvolvimento e lista requisitos de produção como HTTPS, chave persistente, SMTP e APP_ENV=production. Não foram fornecidos ambiente de deploy ou ensaio de produção. Isso não bloqueia uma demo local preparada; não permite afirmar prontidão para operação pública.

4. Segurança, dados e estrutura

- Observado no código: token CSRF obrigatório em métodos de escrita, comparação segura, cookies de sessão HttpOnly e SameSite=Lax, duração de sessão definida, proteção de áreas empresariais e controle de acesso associado à conta.
- A configuração define cookie Secure quando APP_ENV=production e impede recuperação local nesse modo; a operação em produção ainda depende de variáveis e HTTPS conforme a documentação.

- O schema SQLite organiza usuários, empresas, produtos, pedidos/itens, solicitações, orçamentos, ordens e histórico, com chaves estrangeiras e restrições de status/valores.
- Testes de pedidos verificam controle de acesso/CSRF, rejeição de carrinho inválido, baixa e reversão de estoque, sequência de status e atomicidade em falha SQL.
- Testes de dados empresariais verificam acesso restrito, isolamento por empresa autenticada, CSRF, dados inválidos e duplicidade de CNPJ.

Limite: esta é uma revisão direcionada, não um pentest. Não foi executado teste de carga, revisão completa de acessibilidade, validação SMTP nem avaliação de implantação.

5. Execução dos testes e inspeção de páginas

VERIFICAÇÃO	RESULTADO	OBSERVAÇÃO
Suíte automatizada existente	20 aprovados	unittest discover -s BackEnd/tests
Primeira tentativa no sandbox	Falha ao criar banco temporário	O %TEMP% do sandbox não permitiu escrita; não foi erro funcional dos testes.
Reexecução com TEMP/TMP em .test-tmp	20 aprovados	Mesma suíte concluída com sucesso.
Páginas HTML	25 percorridas	Páginas públicas 200; páginas protegidas retornaram 302 sem sessão.
CSS, JS e Assets locais	Sem erros HTTP encontrados	Todos os recursos locais percorridos retornaram 200.
UI em múltiplos viewports	Não executada	Exige inspeção visual real em navegadores/tamanhos variados.

6. Melhorias pontuais priorizadas para o MVP

PRIORIDADE	AÇÃO	VALOR PARA A APRESENTAÇÃO
Antes de apresentar	Ajustar a fala/rótulo da IdeiaAI e deixar explícito que preço/prazo são indicativos.	Evita prometer uma integração ou precisão que o sistema não oferece.
Antes de apresentar	Ensaiar o percurso com conta cliente e conta empresa preparadas; validar solicitação, orçamento, decisão e acompanhamento.	Reduz risco de bloqueio por cadastro, sessão ou ausência de dados.
Antes de apresentar	Ensaiar na rede/local do evento; testar CEP manual e tipografia carregada.	Diminui dependência de serviço externo durante a demonstração.
Se houver tempo	Conferir estoque, produtos ativos, imagens e pedidos de demonstração; usar dados fictícios.	Ajuda a evitar telas vazias e dados pessoais expostos.
Após a apresentação	Adicionar testes de integração para atendimento, orçamento, recuperação, endereço/frete e ordens de serviço.	Dá confiança aos fluxos ainda descobertos pela suíte atual.
Antes de uso público	Validar implantação com HTTPS, chave persistente, SMTP, recuperação e estratégia de backup.	Fecha lacunas entre demo local e serviço operacional.

7. Roteiro sugerido para a demonstração

- Entrar com conta empresarial preparada e mostrar painel e indicadores.
- Como cliente, abrir solicitação de assistência, preencher problema e obter a triagem preliminar.
- Alternar para a empresa, apresentar a solicitação e registrar/propor o orçamento disponível no sistema.
- Voltar ao cliente para demonstrar decisão e acompanhamento, usando registros previamente preparados.
- Mostrar vitrine, carrinho e pedido se o estoque e as contas estiverem conferidos.
- Manter servidor local iniciado, navegador na página inicial e plano simples de retorno caso a rede externa falhe.

8. Limites e parecer final

A auditoria não exercitou cada formulário/transição pela interface, nem realizou teste visual multiplataforma, carga, pentest, auditoria completa de acessibilidade, teste SMTP ou deploy. O resultado é uma avaliação de prontidão baseada nos testes existentes, smoke test HTTP e inspeção de código/configuração. Portanto, não se deve interpretar os 20 testes aprovados como cobertura integral.

Parecer: o MVP pode ser demonstrado localmente com roteiro guiado e dados previamente preparados. Corrigir a narrativa da IdeiaAI e ensaiar o fluxo que será mostrado são as medidas de maior impacto para amanhã à tarde.